MICROSOFT ENTRA ID

Break Glass Account

Best Practices Guide

1. Overview – What is a Break Glass Account?

Emergency access accounts, commonly known as break glass accounts, are highly privileged cloud-only accounts in Microsoft Entra ID designed for use during emergency or crisis scenarios when normal administrative accounts cannot be used.

These accounts are assigned the Global Administrator role permanently and are intended as a last resort to prevent complete lockout from a Microsoft Entra tenant.

> **Recommendation**
> Organizations should maintain two or more cloud-only emergency access accounts that use the *.onmicrosoft.com domain and are not federated or synchronized from an on-premises environment.

2. Why You Need Emergency Access Accounts

There are several critical scenarios where break glass accounts become essential:

- **Federation outage:** If your identity provider goes down, users cannot sign in through Microsoft Entra ID redirection.
- **MFA service unavailability:** When all administrators are registered with MFA and their devices or the MFA service become unavailable (e.g. cell network outage).

- **Last Global Admin departed:** When the person with the most recent Global Administrator access has left the organization.
- **Natural disasters:** Unforeseen circumstances during which mobile phones or other networks might be unavailable.
- **PIM role activation failure:** When role assignments for Global Administrator and Privileged Role Administrator require approval but no approvers are available in the directory.

> ⚠ **Critical Warning**
> Without properly configured emergency access accounts, a misconfigured Conditional Access policy or an MFA outage could result in complete tenant lockout with no self-service recovery option.

3. Account Creation Best Practices

Follow these recommended steps when creating emergency access accounts in the Entra admin center:

3.1 Create Two Cloud-Only Accounts

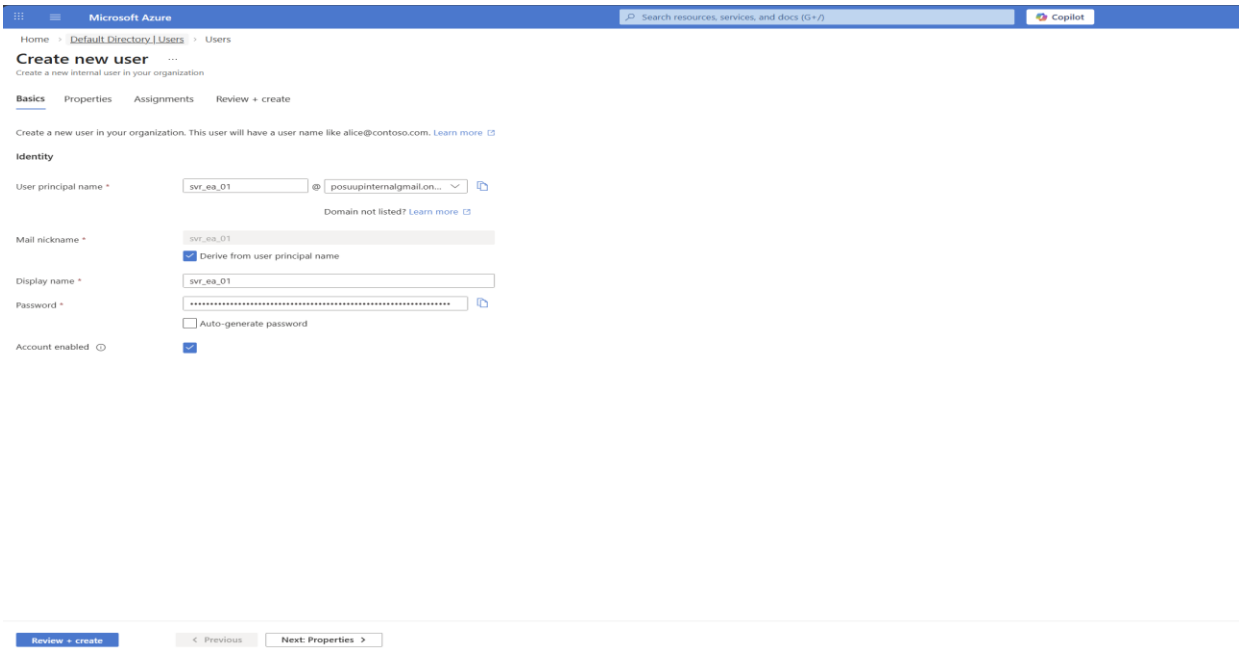
Navigate to the Microsoft Entra admin center and create two emergency access user accounts. These must be cloud-only, using the *.onmicrosoft.com domain.

Portal Path: Microsoft Entra admin center → Identity → Users → All users → + New user → Create user

3.2 Naming Conventions

It is recommended avoiding obvious names that could reveal the account's purpose to attackers during password spraying or reconnaissance:

DO NOT Use	Recommended Instead
breakglass@contoso.onmicrosoft.com	svr_ea_01@contoso.onmicrosoft.com
emergencyaccess@contoso.onmicrosoft.com	alex.morgan@contoso.onmicrosoft.com
admin-emergency@contoso.onmicrosoft.com	Random human-like display name

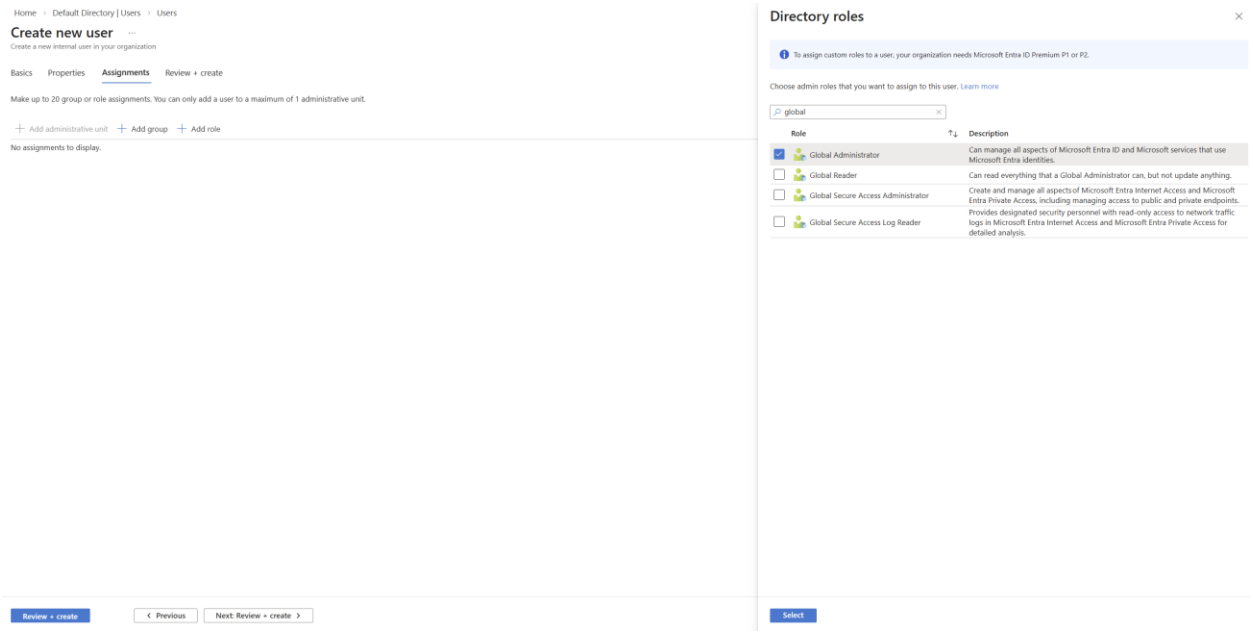


Please make sure to uncheck Auto generate Password option and use minimum 32-digit complex password. Click Next and Go to Assignments:

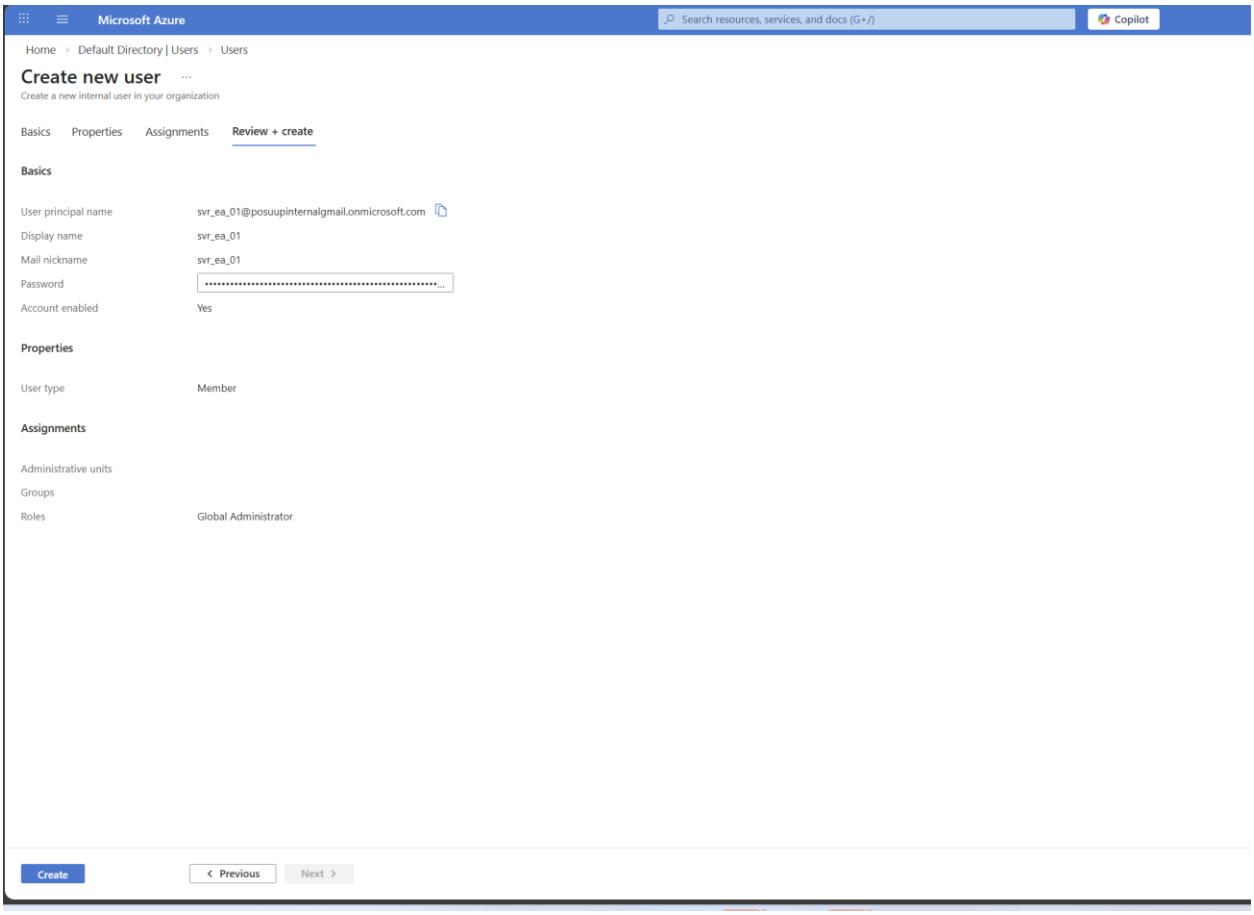
3.3 Assign Global Administrator Role

Each emergency access account must be permanently (If PIM is activated) assigned the Global Administrator role. This is a critical requirement to ensure full tenant recovery capabilities.

Portal Path: Add assignments → Global Administrator



Click on Select and Click on Next: Review + Create



Click on Create.

4. Authentication Configuration

For Security Best practices we will configure passwordless authentication for break glass accounts.

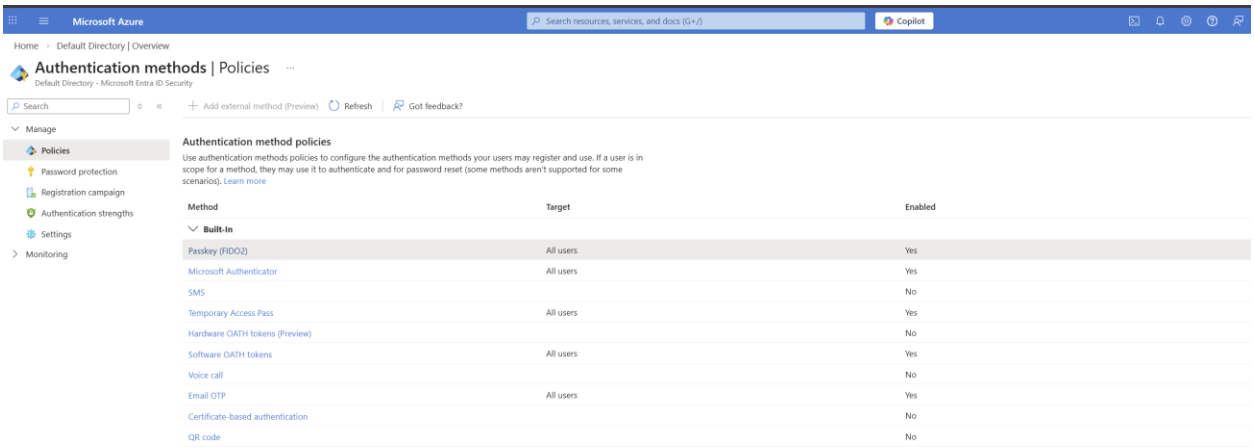
4.1 Recommended Authentication Methods

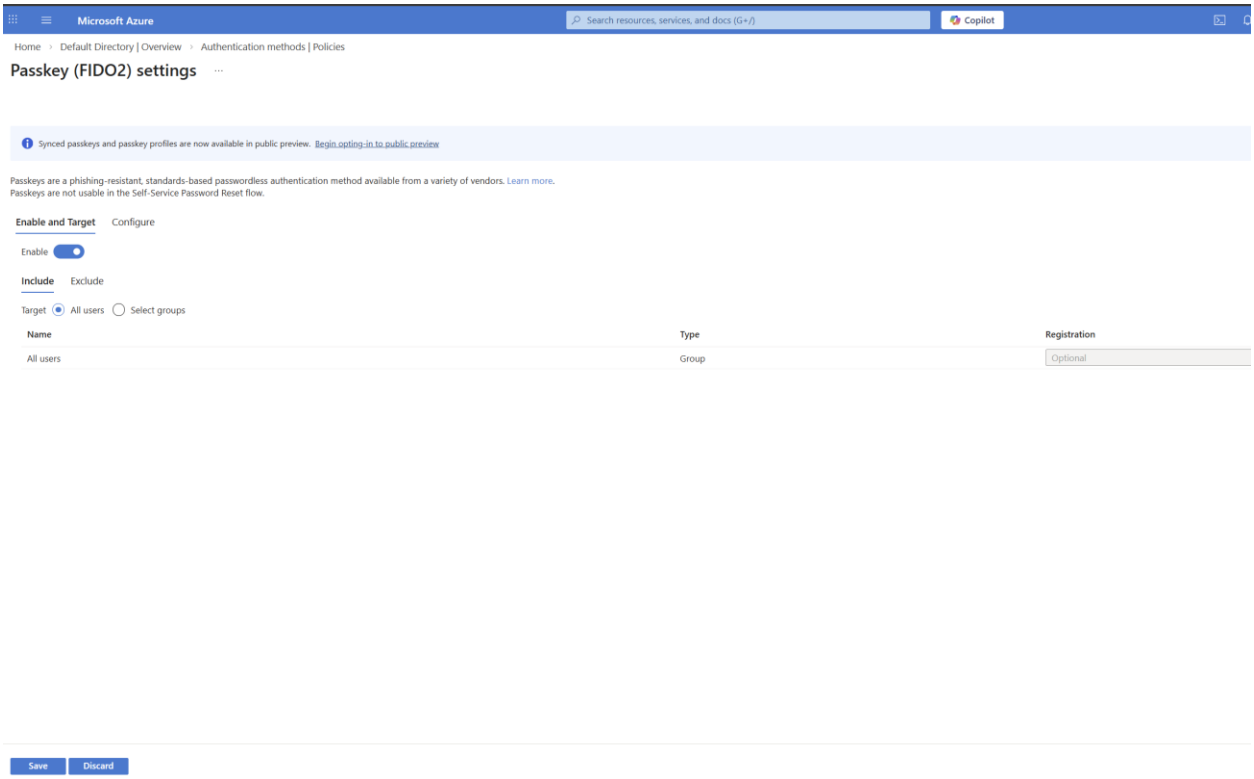
Method	Details	When to Use
Passkey (FIDO2)	Hardware security keys (e.g. YubiKey) that provide phishing-resistant MFA. Microsoft's recommended option.	Default choice for most organizations. Store keys in a secure, fireproof safe.
Certificate-Based Auth (CBA)	Uses X.509 certificates for authentication. Satisfies MFA requirements natively.	If your organization already has a PKI infrastructure in place.

4.2 FIDO2 Setup Steps

1. Enable FIDO2 passkeys for your organization in the Entra admin center.

Path: Entra admin center → Protection → Authentication methods → Policies → Passkey (FIDO2) → Enable

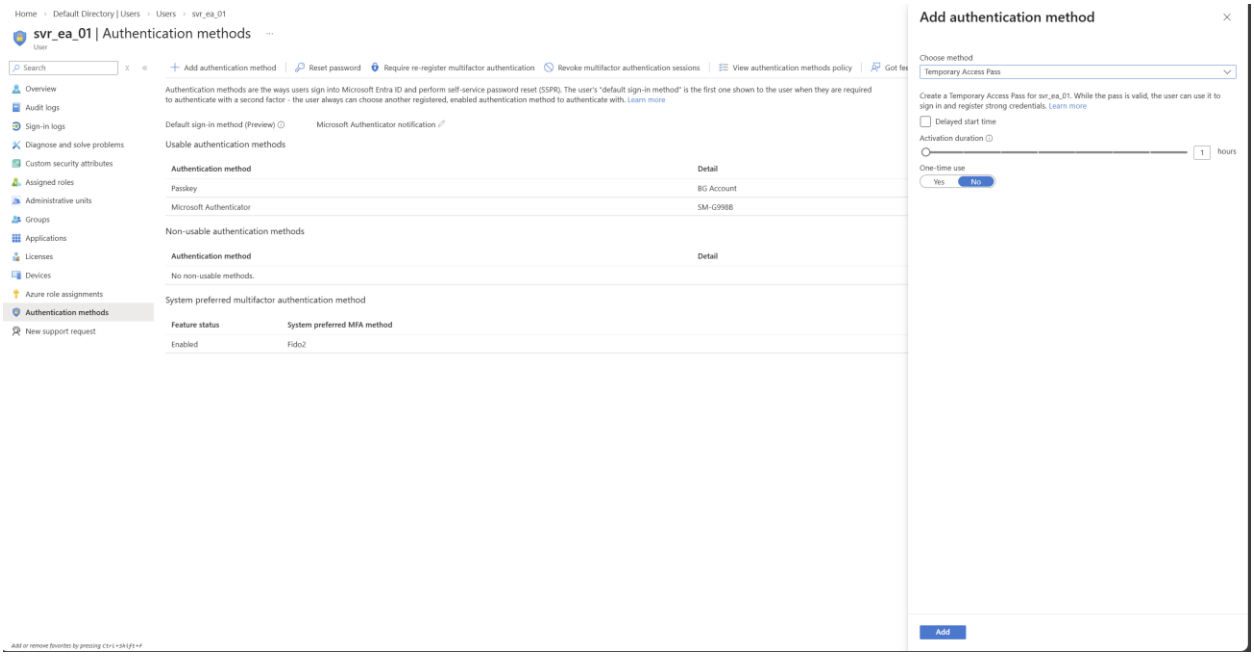


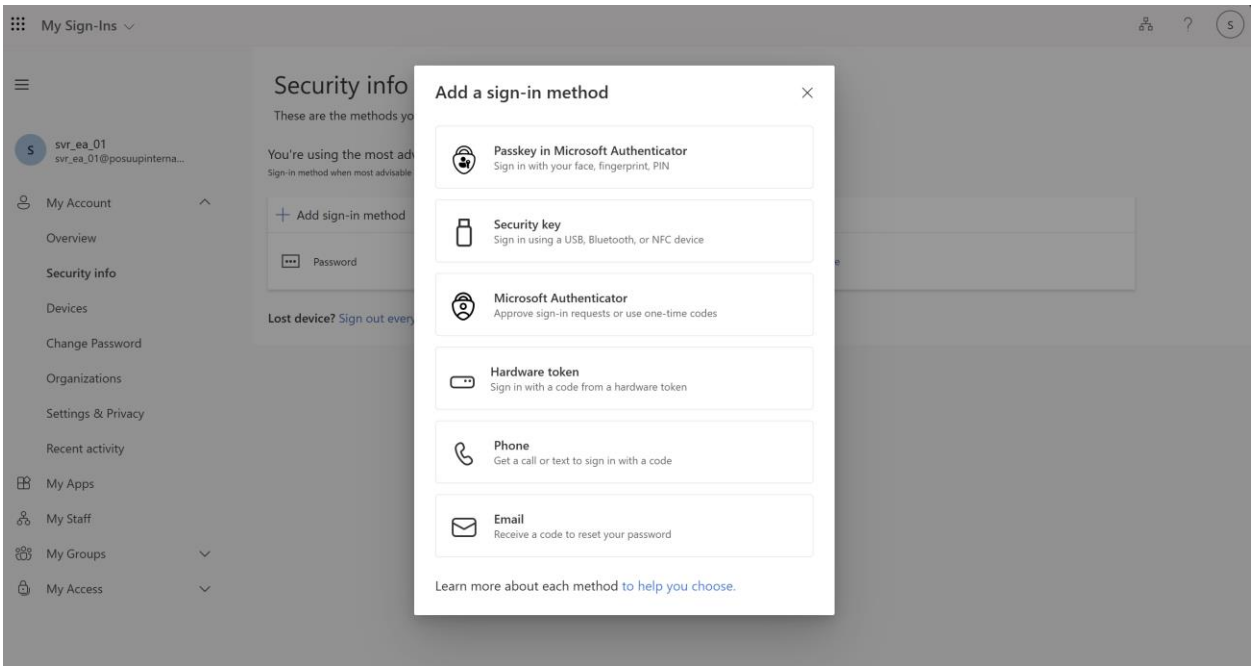


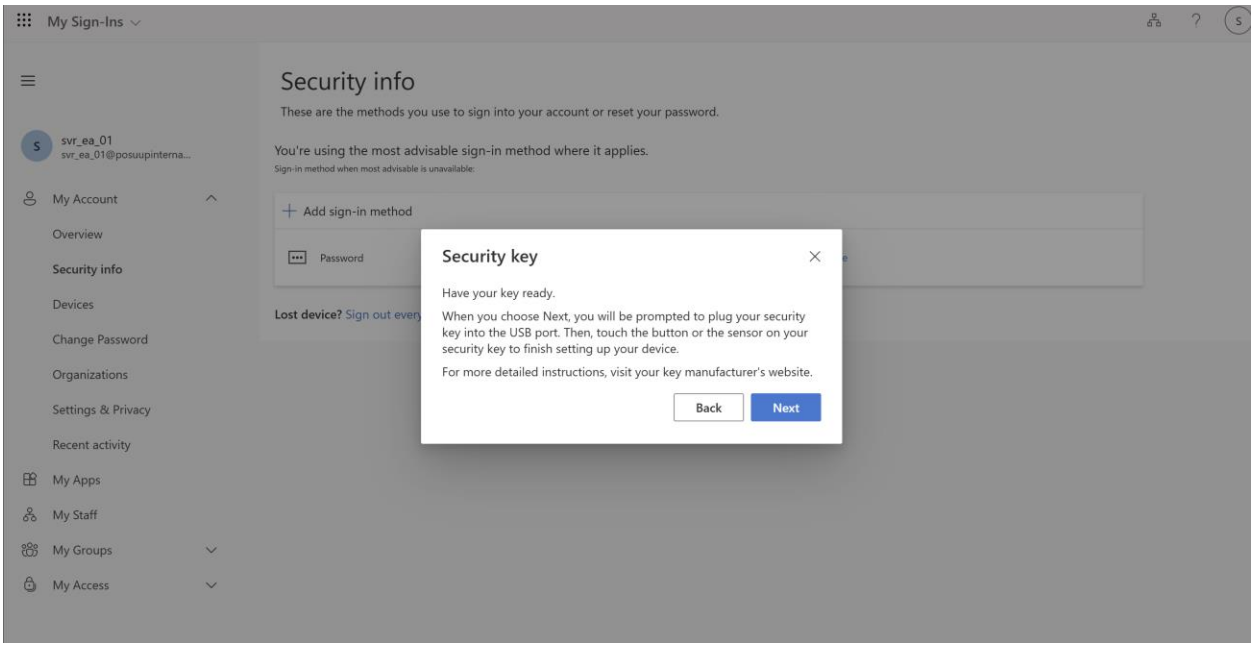
Click on Save.

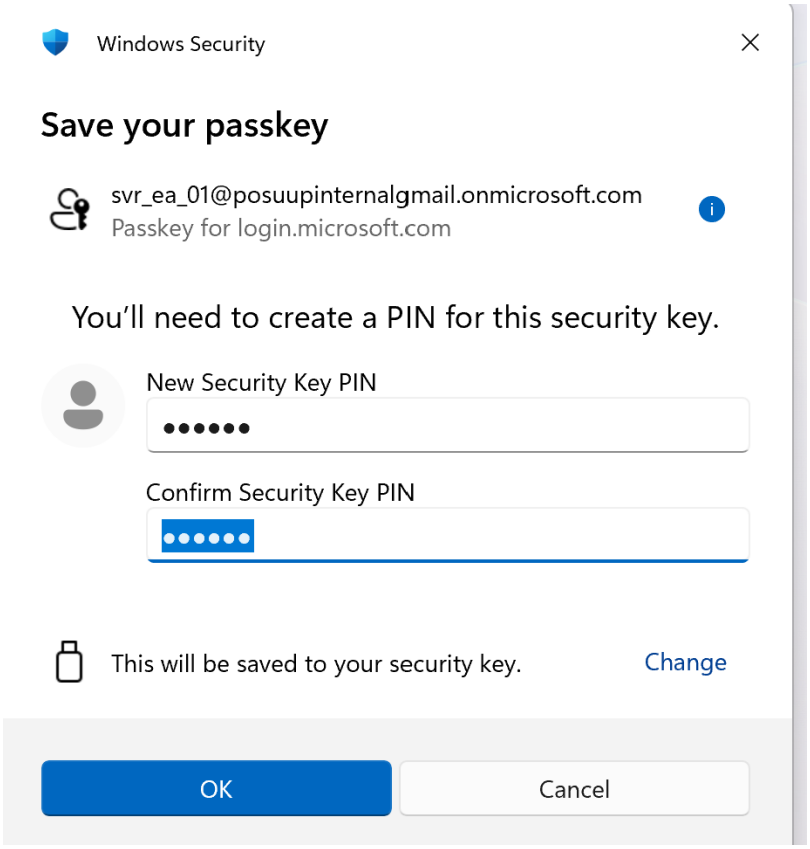
2. Sign in to the emergency account and register the FIDO2 security key. We need to generate TAP(temporary access password) to login to mysign in portal so we don't add MFA for this account to any personal phone. Once we generate TAP then we need to login to Security portal to setup FIDO key:

Path: https://mysignins.microsoft.com/security-info → + Add sign-in method → Security key

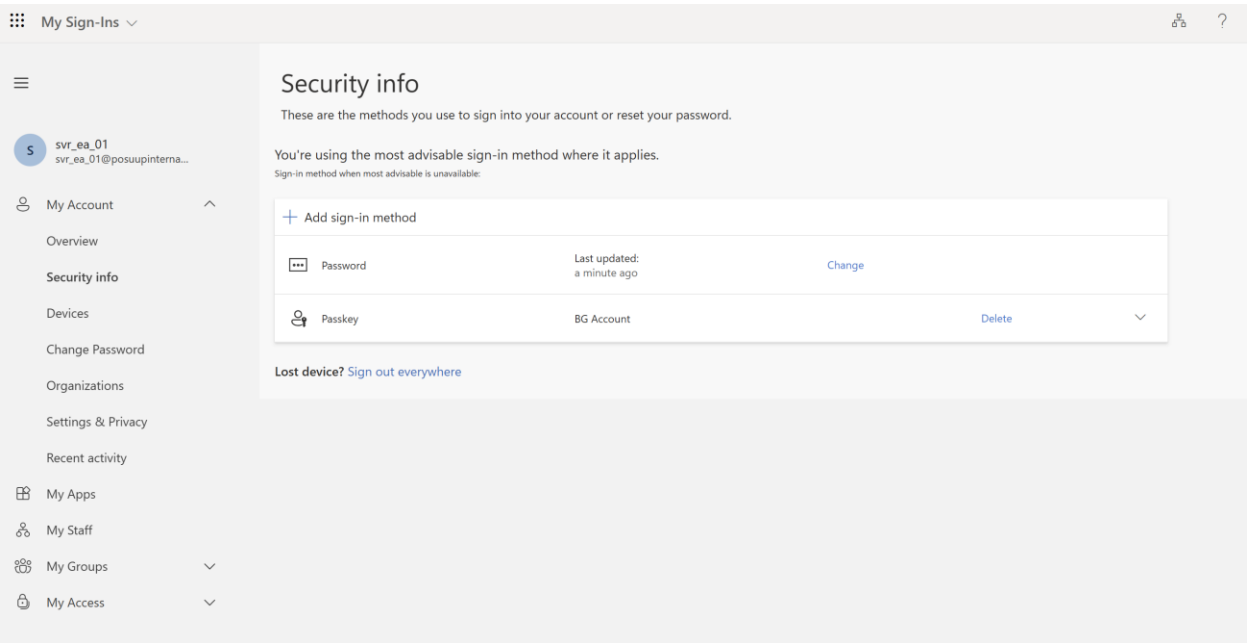

Home > Default Directory | Users > Users > svr_ea_01
svr_ea_01 | Authentication methods
User
Search
Add authentication method
Reset password
Require re-register multifactor authentication
Revoke multifactor authentication sessions
View authentication methods policy
Overview
Audit logs
Sign-in logs
Diagnose and solve problems
Custom security attributes
Assigned roles
Administrative units
Groups
Applications
Licenses
Devices
Azure role assignments
Authentication methods
New support request
Authentication methods are the ways users sign into Microsoft Entra ID and perform self-service password reset (SSPR). The user's "default sign-in method" is the first one shown to the user when they are required to authenticate with a second factor - the user always can choose another registered, enabled authentication method to authenticate with. Learn more
Default sign-in method (Preview)
Microsoft Authenticator notification
Usable authentication methods
Authentication method
Detail
Passkey
BG Account
Microsoft Authenticator
SM-G998B
Non-usable authentication methods
Authentication method
Detail
No non-usable methods.
System preferred multifactor authentication method
Feature status
System preferred MFA method
Enabled
Fido2
Add authentication method
Choose method
Temporary Access Pass
Create a Temporary Access Pass for svr_ea_01. While the pass is valid, the user can use it to sign in and register strong credentials. Learn more
Delayed start time
Activation duration
1
hours
One-time use
Yes
No
Add


My Sign-Ins
Security info
These are the methods yo
You're using the most ad
Sign-in method when most advisable
Add sign-in method
Password
Lost device? Sign out every
svr_ea_01
svr_ea_01@posuupinterna...
My Account
Overview
Security info
Devices
Change Password
Organizations
Settings & Privacy
Recent activity
My Apps
My Staff
My Groups
My Access
Add a sign-in method
Passkey in Microsoft Authenticator
Sign in with your face, fingerprint, PIN
Security key
Sign in using a USB, Bluetooth, or NFC device
Microsoft Authenticator
Approve sign-in requests or use one-time codes
Hardware token
Sign in with a code from a hardware token
Phone
Get a call or text to sign in with a code
Email
Receive a code to reset your password
Learn more about each method to help you choose.





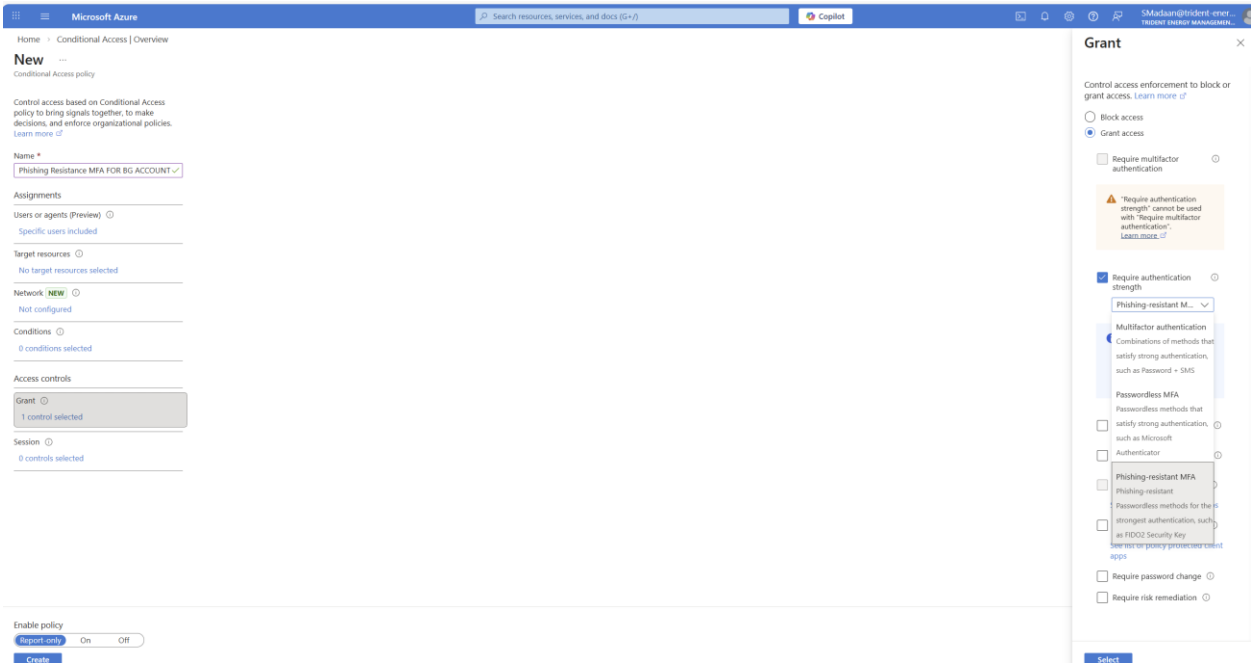
Set the PIN for FIDO Key, Click on OK and register fingerprint.



3. Register at least two FIDO2 keys per account for redundancy. Store each key in a separate secure location.

4. Require phishing-resistant MFA for all emergency accounts via Conditional Access. Go to Conditional Access Policies, Create New Policy, Select the BreakGlass account under Users or Groups.

5. Go to Grant option, Deselect Require multifactor authentication and Select Require Authentication Strength and Select FIDO key option.



> **Important: Different Auth Method Than Regular Admins**
>
> Recommendation: if your normal administrator accounts use Microsoft Authenticator, use a FIDO2 security key for emergency accounts. This avoids single points of failure across authentication methods.

4.3 Key Authentication Rules

- The device or credential must not expire or be subject to automated cleanup due to inactivity.
- Do not register MFA to any individual's personal device or phone number.
- MFA devices must be accessible to multiple authorized administrators and able to communicate via at least two independent network paths.

5. Conditional Access Policy Configuration

Proper Conditional Access (CA) configuration is critical. A misconfigured CA policy is one of the most common causes of tenant lockout.

5.1 Exclude from All CA Policies

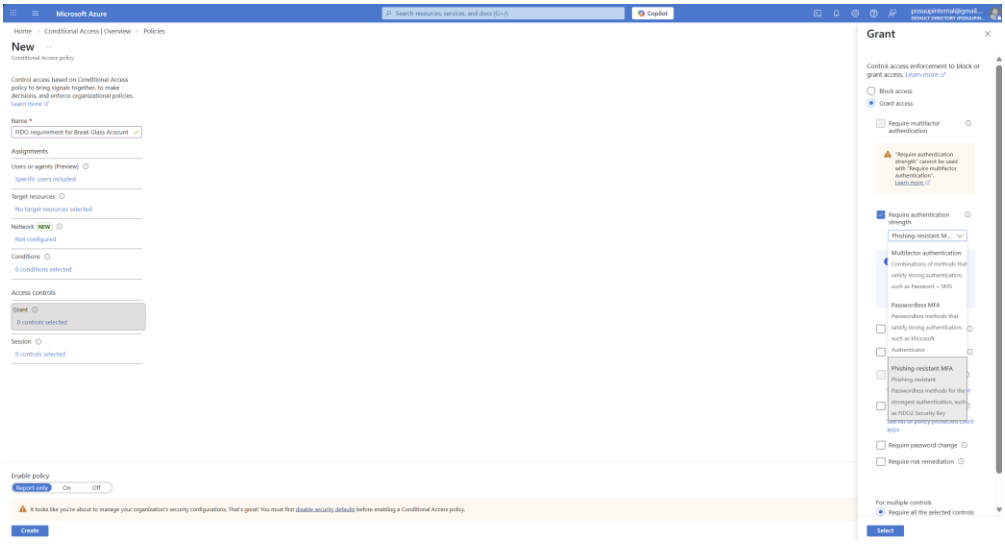
It is recommended that at least one emergency access account be excluded from ALL Conditional Access policies. This ensures the account remains accessible even when CA policies are misconfigured.

Portal Path: Entra admin center → Protection → Conditional Access → Policies → [Each Policy] → Users → Exclude → Users and groups → Add the emergency account

5.2 Create a Dedicated CA Policy for Emergency Accounts

Create a separate Conditional Access policy specifically for emergency accounts that requires phishing-resistant MFA (passkey/FIDO2) only.

1. Create a custom authentication strength named “Emergency Access” that only includes the Passkeys option.
2. Create a Conditional Access policy targeting only the emergency access security group.
3. Set the Grant control to require the custom authentication strength. (we can incorporate **Trusted Locations** to limit logins to verified IP ranges, careful consideration should be given to ensuring access remains possible during a total network or VPN failure.)

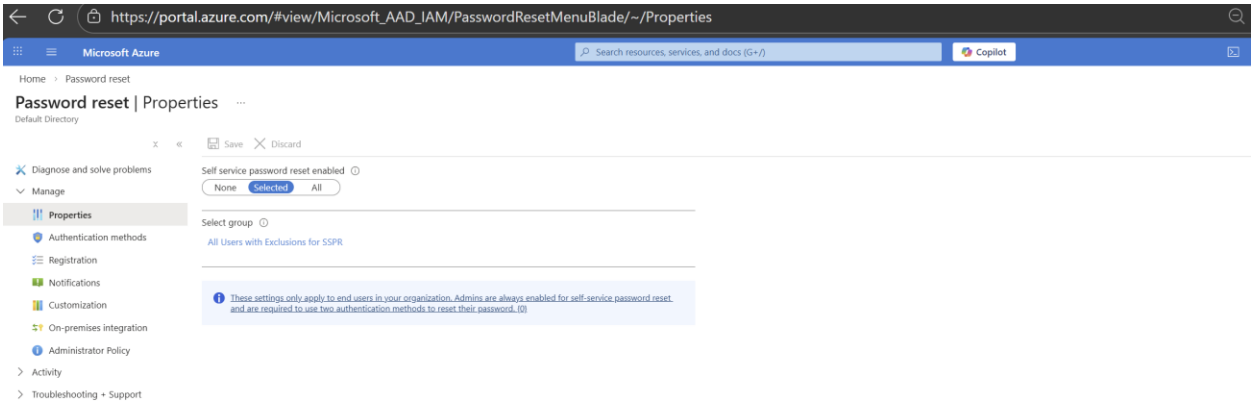


> ⚠ **Mandatory MFA – Important Distinction**
>
> Even though emergency accounts should be excluded from CA policies, Microsoft's mandatory MFA enforcement (applied at the application level, not through CA) will still require MFA when signing into Azure, Entra, and Intune portals. This means your emergency accounts must have FIDO2 or CBA registered, regardless of CA exclusions.

5.3 Use a Security Group for Exclusions

Create a dedicated Microsoft Entra security group (e.g. "BreakGlassAccounts") containing both emergency access accounts. Use this group consistently in all CA policy exclusions to simplify management and reduce the risk of forgetting to exclude individual accounts.

5.4 Make sure we exclude this account from SSPR as well as we don't want to enable self-service password reset option for our critical account.



6. Privileged Identity Management (PIM)

If your organization uses Microsoft Entra Privileged Identity Management, specific configuration is required for emergency access accounts.

6.1 Permanent Active Assignment

Emergency access accounts must have a permanent active role assignment for the Global Administrator role — not an eligible assignment. An eligible assignment would require activation, which might not be possible during the exact emergency scenario you are trying to protect against.

Portal Path: Entra admin center → Identity Governance → Privileged Identity Management → Microsoft Entra roles → Assignments → Add assignments → Assignment type: Active → Permanently assigned

7. Password & Credential Management

7.1 Password Requirements

- Use passwords of at least 32 characters (Microsoft Entra supports up to 256 characters).
- Include a mix of uppercase letters, lowercase letters, numbers, and special characters.
- Set the password policy to “never expire” to prevent lockouts during emergencies.
- Exclude accounts from automated inactive user removal processes.

7.2 Credential Storage

- Write the password on paper and store in a fireproof safe or secure vault.
- Consider splitting the password into two halves stored in separate locations, accessible by different authorized individuals.
- Store FIDO2 security keys in the safe alongside password credentials.
- If using a corporate password manager, strictly limit access and regularly audit permissions.
- Ensure credentials are stored in separate, secure locations with multiple means of communication to Microsoft Entra ID.

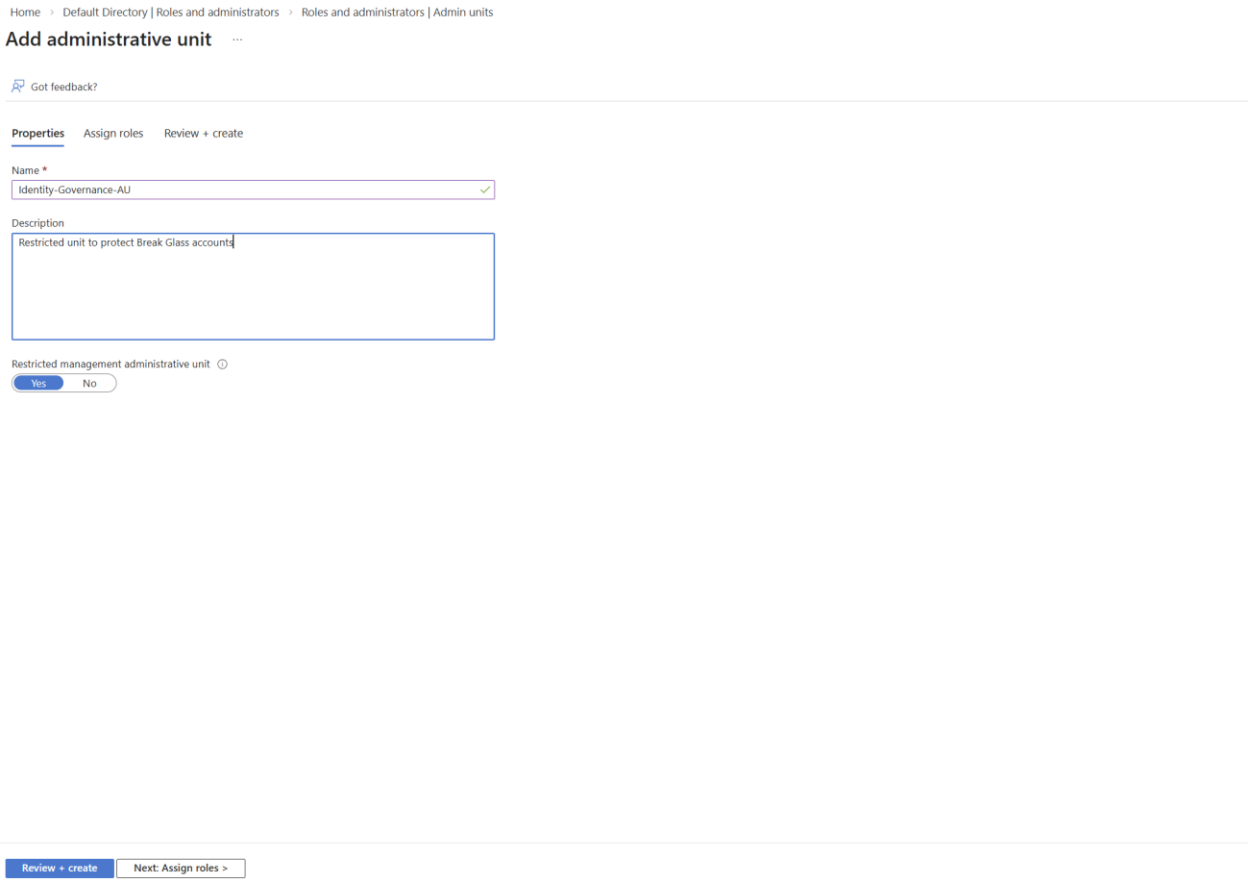
Privileged Access Workstation

It is recommended that authorized individuals use a designated secure workstation (Privileged Access Workstation) when interacting with emergency access accounts.

7. 3 Restricted Access Management

Assign the Emergency Access account to a Restricted Management Unit (RMU) to isolate it from standard administrative tiers. This ensures that management tasks, such as password resets, can only be performed by specifically authorized personnel via Privileged Identity Management (PIM), preventing unauthorized modifications by User or Helpdesk Administrators.

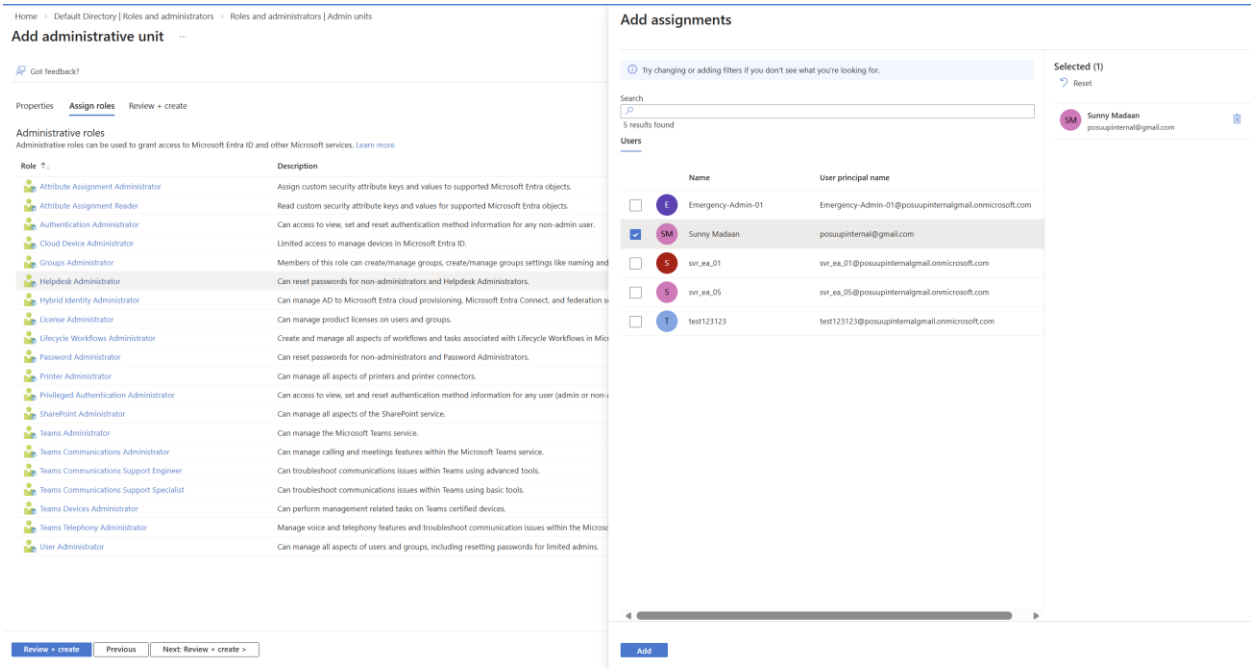
Go to **Entra ID** > **Roles & administrators** > **Admin units**.



Click **+ Add** and enter a professional Name and Description (e.g., *Identity-Governance-AU*).

Crucial Step: Ensure the toggle for "Restricted management administrative unit" is set to Yes. This "locks" the unit, ensuring that only administrators specifically assigned to this unit can manage the members within it.

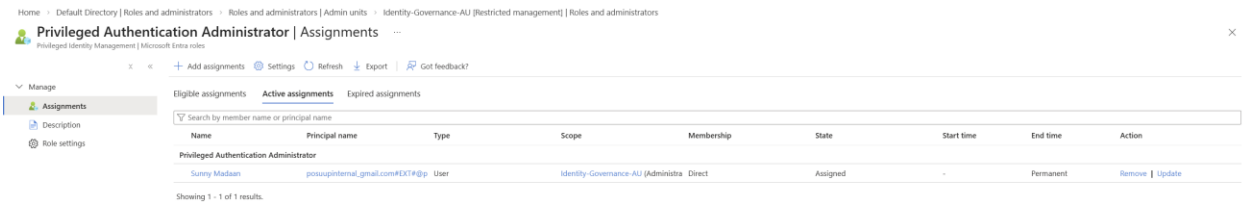
Click on Next to assign roles:

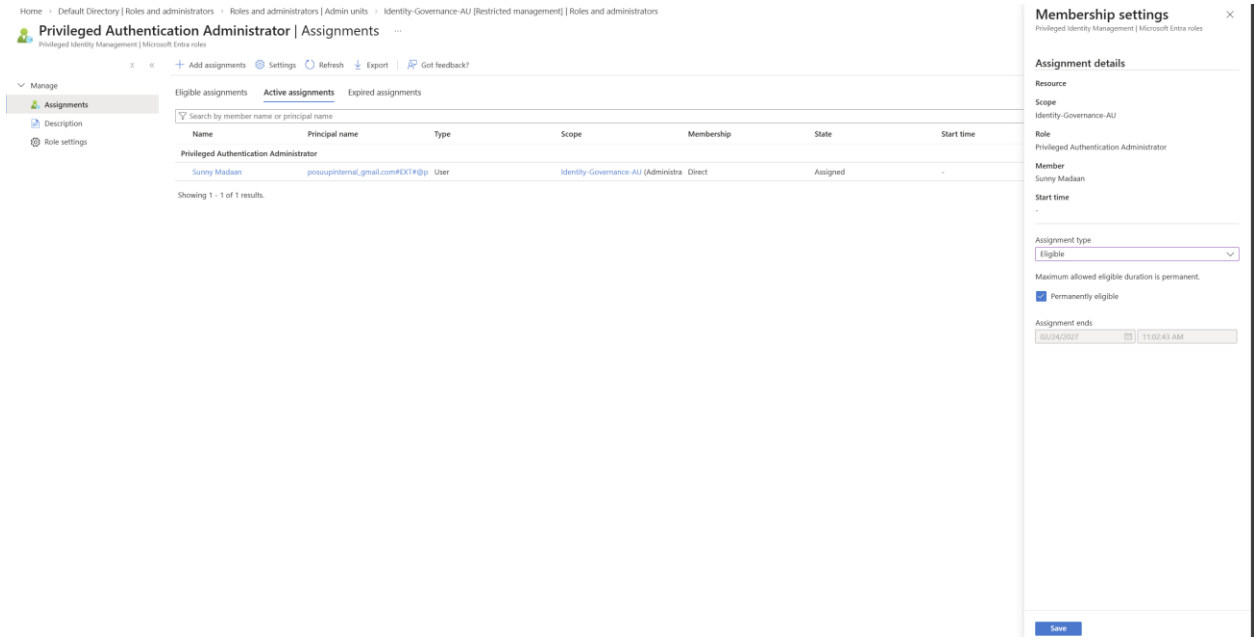


Select the **Privileged Authentication Administrator** role. This role is required to manage credentials and authentication methods for the emergency accounts.

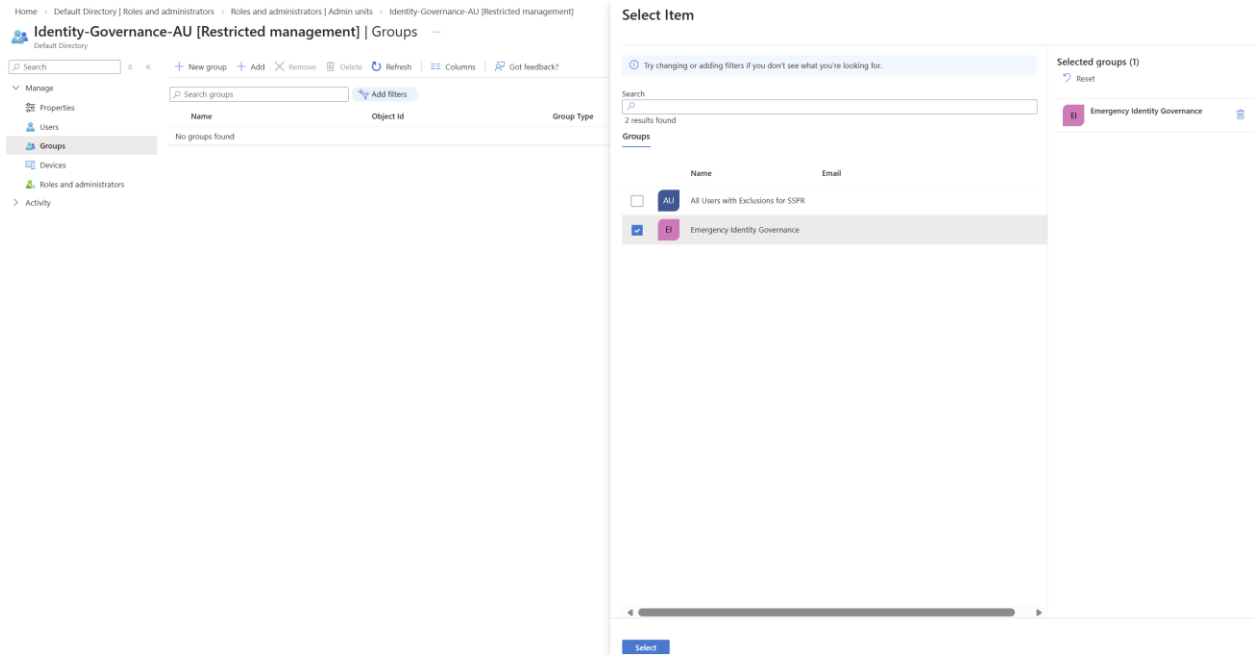
Assign this role to a maximum of one or two highly trusted users (such as your Head of Security) who already hold Global Admin privileges or are part of the core security team.

Security Best Practice: If **Privileged Identity Management (PIM)** is enabled, always set the assignment type to **Eligible** rather than Permanent to maintain a Zero-Trust posture.





Finalize the process by adding the **Security Group** containing your emergency accounts to the Administrative Unit. This creates a logical "shield" around those accounts, isolating them from unauthorized password resets or modifications by standard helpdesk tiers.



8. Monitoring & Alerting

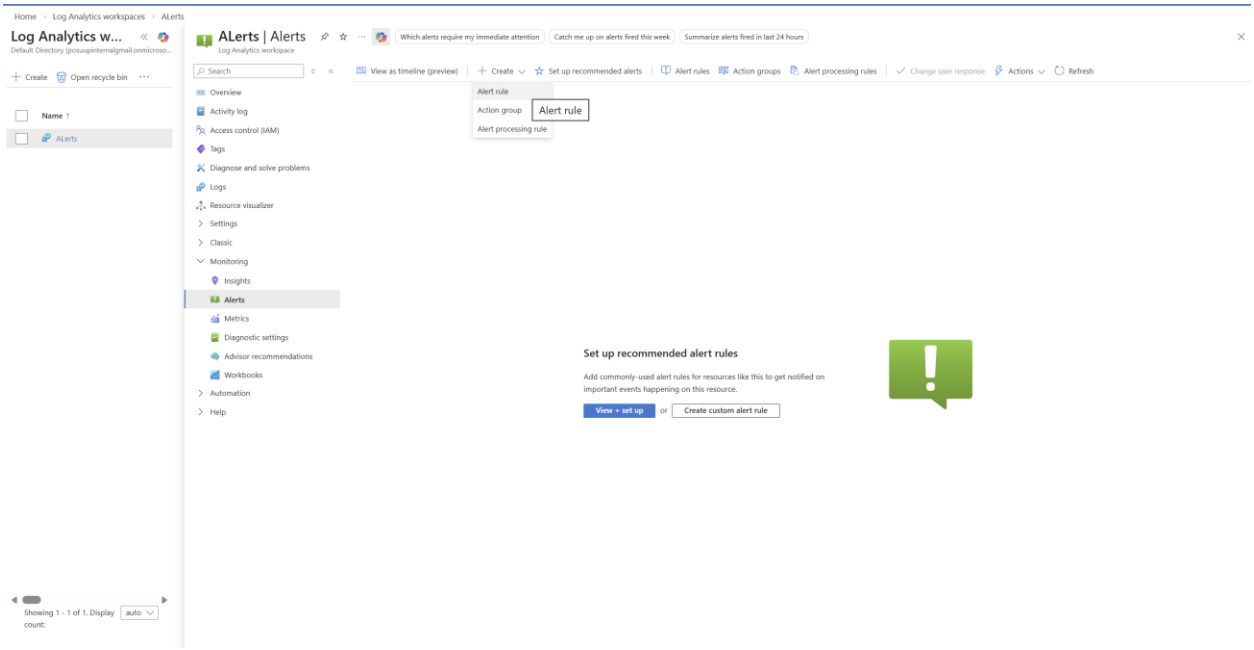
Every sign-in to an emergency access account should trigger immediate notifications. We need to setup monitoring using Azure Monitor and Microsoft Sentinel.

8.1 Set Up Sign-In Log Monitoring

1. Send Microsoft Entra sign-in logs to an Azure Log Analytics workspace for long-term retention.

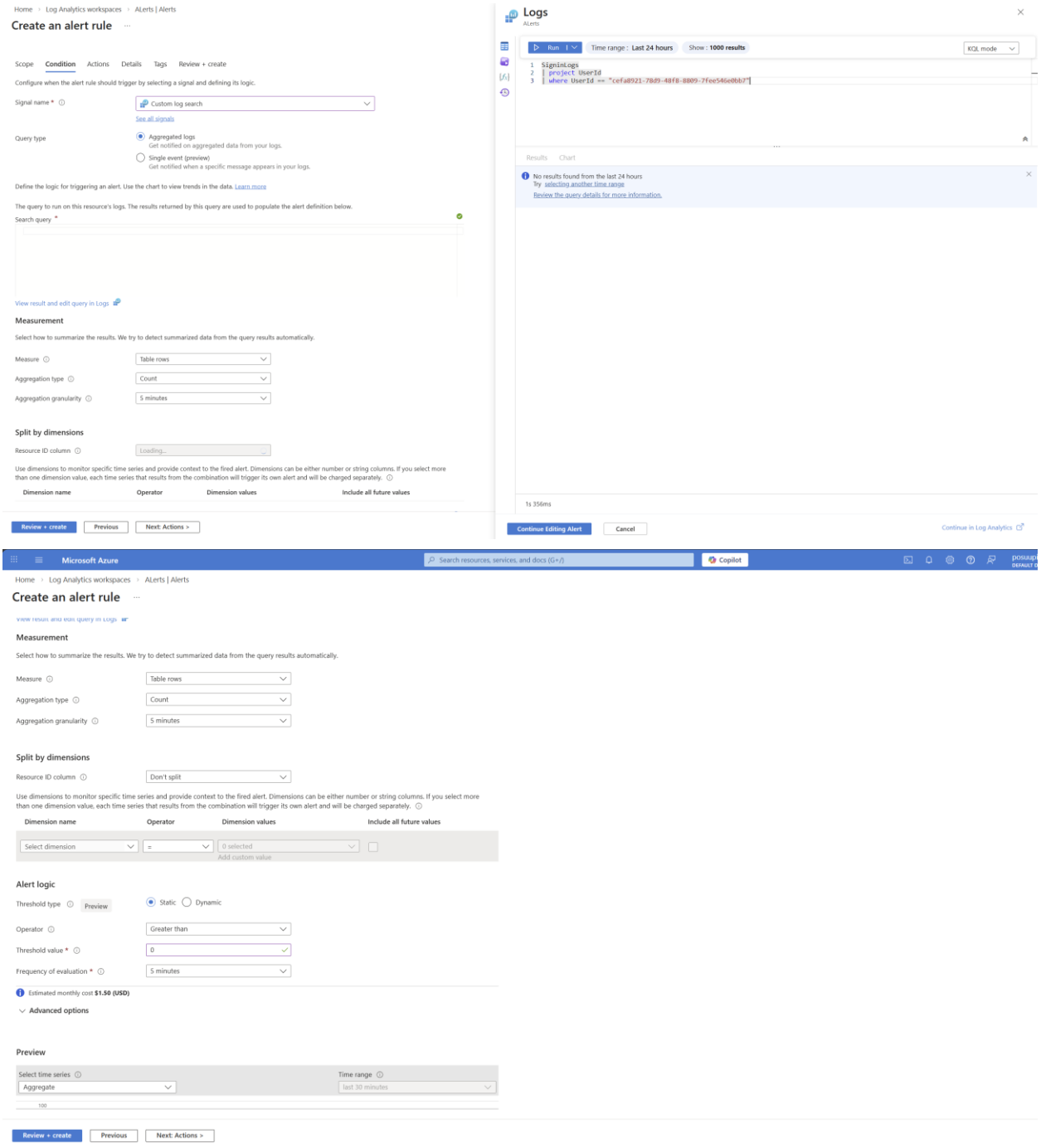
Path: Entra admin center → Identity → Monitoring & health → Diagnostic settings → + Add diagnostic setting → Select SignInLogs and AuditLogs → Send to Log Analytics workspace

2. Obtain the Object IDs of both emergency access accounts from Entra admin center → Users.
3. Create an alert rule in Azure Monitor using a custom log search query.



8.2 Sample KQL Query

```
SigninLogs
| project UserId
| where UserId == "<ObjectID-Account1>"
    or UserId == "<ObjectID-Account2>"
```



Creating an alert will not only send notification in case of successfully login from this account but also if there is any login attempt which is a failure event as well to detect any suspicious activity.

8.3 Alert Configuration

Setting	Value
Based on	Number of results
Operator	Greater than
Threshold value	0
Severity level	**Critical (Sev 0)**
Action group	Email/SMS/Push/Voice notification to global admins

9. Regular Validation & Testing

Emergency access accounts must be validated regularly to ensure they function when needed. The following steps should be performed at minimum every 90 days:

- Ensure security-monitoring staff know that account-check activity is ongoing.
- Review and update the list of individuals authorized to use emergency account credentials.
- Ensure the emergency break glass process is documented and current.
- Train administrators and security officers on the emergency process.
- Validate that the accounts can sign in and perform administrative tasks.
- Verify MFA devices are accessible and can communicate via at least two independent network paths (e.g. facility Wi-Fi and cellular).
- Change safe combinations after anyone with access leaves the organization.

Additional triggers for validation beyond the 90-day cycle include: recent changes in IT staff, terminations, position changes, and changes to Microsoft Entra subscriptions.

10. Quick Reference Checklist

#	Best Practice	Status
1	Create two cloud-only emergency access accounts	☐
2	Use *.onmicrosoft.com domain (not custom domain)	☐
3	Use non-obvious, randomized display names	☐
4	Assign permanent active Global Administrator role	☐
5	Register FIDO2 security keys (minimum 2 per account)	☐
6	Use different auth method than regular admin accounts	☐
7	Exclude at least one account from all CA policies	☐
8	Create dedicated CA policy for emergency accounts	☐
9	Set password to never expire (≥32 characters)	☐
10	Store credentials in fireproof safe(s)	☐
11	Implementing Administrative Isolation using RMU	☐
12	Configure Azure Monitor sign-in alerts (Sev 0)	☐

13	Forward sign-in logs to Log Analytics workspace	☐
14	Do not associate accounts with any individual	☐
15	Do not sync from on-premises AD	☐
16	Use Privileged Access Workstation for access	☐
17	Validate accounts at least every 90 days	☐
18	Document and train staff on emergency procedures	☐
19	Set up post-mortem review process	☐

11. Key Portal Navigation Paths

Quick reference for all Entra admin center paths referenced in this guide:

Action	Navigation Path
Create user	Entra admin center → Identity → Users → All users → + New user
Assign role	Users → [User] → Assigned roles → + Add assignments
Enable FIDO2	Protection → Authentication methods → Policies → Passkey (FIDO2)
Register security key	https://mysignins.microsoft.com/security-info
Exclude from CA	Protection → Conditional Access → [Policy] → Users → Exclude
PIM assignment	Identity Governance → PIM → Microsoft Entra roles → Assignments
Diagnostic settings	Identity → Monitoring & health → Diagnostic settings
Alert rules	Azure Portal → Monitor → Log Analytics → Alerts → New alert rule
User Object ID	Users → [User] → Overview → Object ID